Ders 5 Çalışma Özeti

Ders 5 Çalışma Özeti

Genel Konular

- Unix/Linux güvenlik modelinin genişletilmesi
  - Dosya sistemi kökü, kullanıcı kimlikleri, servis hesapları, yetki denetimi ve sistem çağrıları güvenlik açısından değerlendirilir.
  - `chroot` benzeri sınırlandırma mekanizmalarının saldırganı dar bir dosya sistemi görünümüne hapsetme amacı açıklanır.
- Sandbox yaklaşımı
  - Güvenilmeyen kodun sınırlı kaynaklarla ve sınırlı sistem çağrılarıyla çalıştırılması temel savunma yöntemi olarak ele alınır.
  - Sandbox yalnızca dosya erişimi değil; bellek, ağ, proses ve kernel etkileşimi açısından da sınır koymalıdır.
- Sistem çağrıları ve kalıcı etki
  - Tüm sistem çağrıları aynı risk düzeyinde değildir; dosya yazma, proses sonlandırma, ağ erişimi ve yetki değiştirme gibi çağrılar daha dikkatli denetlenmelidir.
  - Salt okuma davranışı bile hassas bilgi sızdırma riski oluşturabilir.
- Zararlı yazılım davranışları
  - Malware çalıştığı ortamı analiz ederek sandbox içinde olup olmadığını anlamaya çalışabilir.
  - Ortam tespiti, saldırı kodunun davranış değiştirmesine veya beklemeye geçmesine neden olabilir.
- Donanım ve bellek destekli savunmalar
  - Kullanıcı alanı, kernel alanı, TLB ve bellek erişim denetimleri güvenlik sınırlarının uygulanmasında kullanılır.

Hocanın Özellikle Vurguladığı Kısımlar

- Sandbox mutlak güvenlik değildir
  - Saldırgan sandbox tespiti yapabilir veya izin verilen dar aralıktaki sistem çağrılarını kötüye kullanabilir.
- Kalıcı zararlı etki oluşturan çağrılar önceliklidir
  - Denetim mekanizmaları tüm çağrılara aynı sertlikte davranmak yerine riskli işlemlere odaklanmalıdır.
- Kullanıcı ve kernel alanı ayrımı kritiktir
  - Kernel alanına kaçış, sıradan uygulama zafiyetini sistem geneli ele geçirmeye dönüştürebilir.

Kısa Tekrar Notları

- `chroot`, dosya sistemi görünümünü sınırlar.
- Sandbox, güvenilmeyen kodu izole çalıştırır.
- Sistem çağrıları güvenlik politikasının uygulanma noktasıdır.
- Malware sandbox ortamını algılamaya çalışabilir.
- Kernel alanına geçiş en kritik risklerden biridir.

Detaylı Açıklamalar

- Unix/Linux modelinde birçok kaynak dosya gibi temsil edildiği için erişim denetimi dosya sistemi kavramıyla yakından ilişkilidir. Kök dizin, kullanıcı kimliği, servis hesabı ve izinler birlikte düşünülür. `chroot`, bir prosesin görebildiği dosya sistemi ağacını değiştirerek saldırganın gerçek sistem dosyalarına ulaşmasını zorlaştırır.
- Sandbox yaklaşımı, güvenilmeyen kodun çalıştırılmasını tamamen yasaklamak yerine, etkisini sınırlı bir çevreye hapsetmeyi hedefler. Bu çevrede dosya erişimi, ağ erişimi, proses oluşturma, sistem çağrıları ve bellek erişimleri politika ile denetlenir.
- Sistem çağrılarının güvenlik etkisi farklıdır. Dosya açma çağrısı yalnızca okuma modunda daha düşük riskli görünse de hassas veri sızdırabilir; yazma, silme, proses öldürme veya yetki değiştirme ise kalıcı ve yıkıcı etki oluşturabilir.
- Zararlı yazılımlar sanal makine, sandbox, anormal zamanlama, kısıtlı donanım veya özel dosya izleri gibi göstergelerden analiz ortamında olduklarını anlayabilir. Bu nedenle sandbox tasarımında yalnızca kısıtlama değil, ortamın gerçekçi görünmesi de önemlidir.
- **Not:** İsterseniz bu dersin altyazı (.srt) dosyasını Gemini Notebook gibi bir yapay zeka aracına yükleyerek ders hakkında daha detaylı soru-cevaplar yapabilir ve dersi verimli çalışabilirsiniz.